

Key Vault: Access Policies vs. Azure RBAC



AZ-500 Exam Prep & Security Architecture

The Payload: What Are We Protecting?



The diagram illustrates a vault system with three distinct compartments, each represented by a stylized safe. The 'Secrets' compartment on the left contains a string of hexadecimal characters. The 'Keys' compartment in the middle features a shield and a key icon. The 'Certificates' compartment on the right shows a document with a lock and a signature. All three compartments are interconnected by a network of lines, suggesting a unified security system.

"[A1b2C3d4E5f6G7h8]"

Secrets

Arbitrary strings and credentials (e.g., passwords, API tokens, database connection strings).



Keys

Cryptographic material used directly for encrypt/decrypt or signing operations (e.g., RSA, EC).



Certificates

TLS/SSL certificates, inherently backed by a private key managed by the vault.

The Two Planes of Access

Management Plane

Governs the vault resource itself.
Actions: Create, delete, configure network rules, or assign access.



Data Plane

Governs access to the payload.
Actions: Read secret values, use cryptographic keys, issue certificates.



Vault Access Policies (The Legacy Model)

Direct Permission List

Permissions are managed directly inside the specific vault's resource settings, rather than through central Azure IAM.

The Silo Effect

Creates an isolated management silo detached from standard Azure RBAC, making centralized auditing difficult.

Security Risk

A user with 'Contributor' rights on the Management Plane can edit this policy, granting themselves full Data Plane access.



The Whole-Vault Limitation

The Rule

Access Policies are applied exclusively at the whole-vault level.

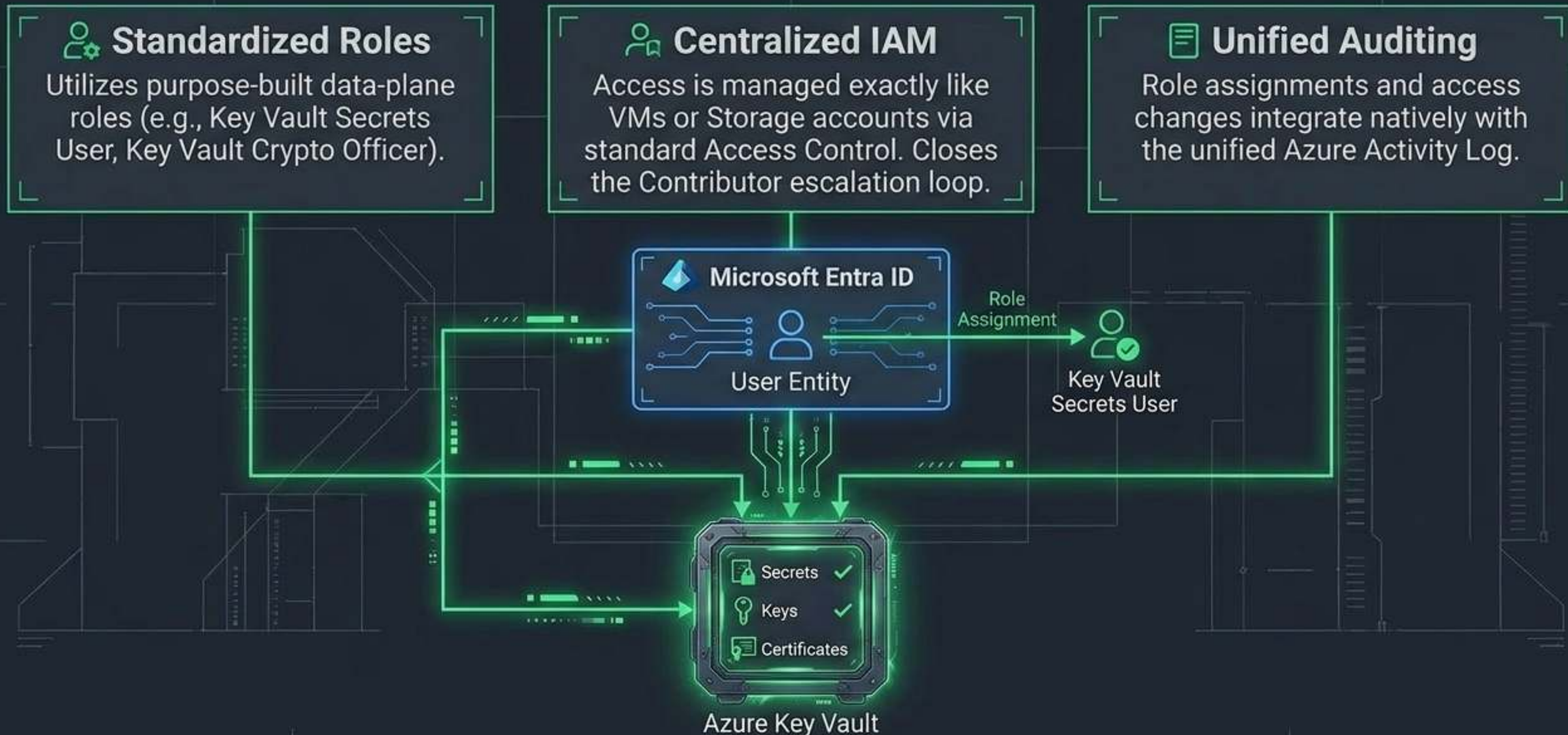
The Consequence

Zero per-object granularity. If you grant a workload 'Secret Read' access to get one database connection string, that workload can now read every secret stored in that vault.



NO PRECISION / ZERO GRANULARITY

Azure RBAC (The Modern Standard)



Object-Level Precision

The Rule

Azure RBAC enables granularity down to individual keys, secrets, or certificates.

The Consequence

Principle of Least Privilege. You can grant a web application read-only access to its specific API key without exposing the rest of the vault's payload.



Precision and Least Privilege: Only One Secret Exposed

The Diagnostic Comparison Matrix

Model	Where Configured	Granularity	Audit Trail	Recommendation
 Access Policies	Vault settings	Whole-vault level	Vault-specific	Legacy approach
 Azure RBAC	Access control (IAM)	Object level	Unified Azure Activity Log	Microsoft Recommended ✓

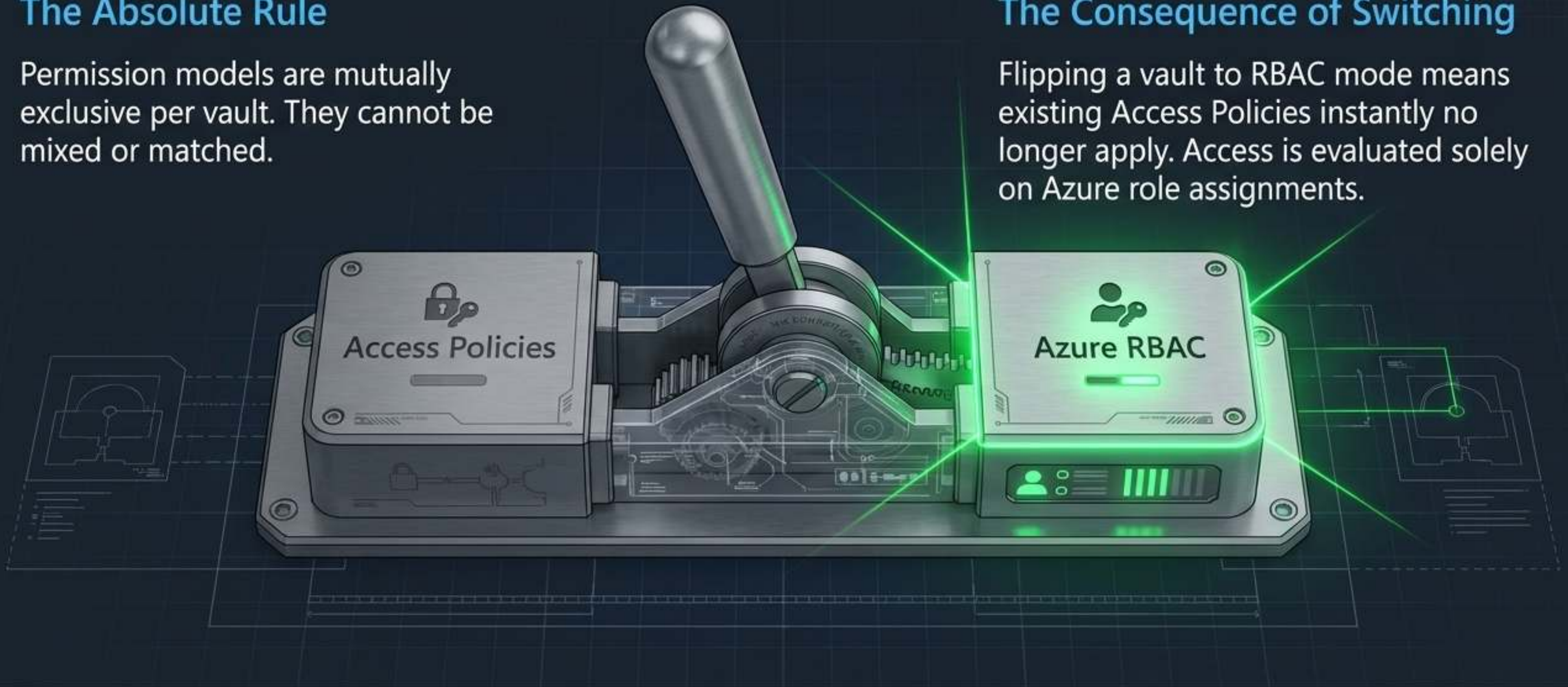
The Switch-Over: Mutually Exclusive Models

The Absolute Rule

Permission models are mutually exclusive per vault. They cannot be mixed or matched.

The Consequence of Switching

Flipping a vault to RBAC mode means existing Access Policies instantly no longer apply. Access is evaluated solely on Azure role assignments.



Migration Mechanics: Transitioning Safely

Step 1: Audit & Map

Identify all current workloads relying on Vault Access Policies.

Step 2: Recreate in IAM

Create the equivalent Azure RBAC role assignments before altering the vault configuration.

Step 3: Flip the Switch

Toggle the vault's permission model to Azure RBAC. The newly created IAM roles take over seamlessly.

AZ-500 Scenario: Granular Requirements

The Scenario

Your architecture requires an application to have **read-only access to exactly one specific secret**. It must be **mathematically prevented** from viewing any other secrets in the vault.

The Solution **Azure RBAC**



Rationale: Only Azure RBAC allows **scope mapping** at the individual object level. **Legacy Access Policies** would over-provision access to the entire vault.

AZ-500 Scenario: Legacy Continuity

The Scenario

An older production vault is currently configured in legacy mode. A new security engineer joins the team and requires access to manage certificates in this vault today.

The Solution

Vault Access Policy



Rationale: Because permission models are mutually exclusive, you cannot assign an RBAC data-plane role to a user if the vault is configured for Access Policies. You must use the active model.

AZ-500 Scenario: Compliance & Auditing

The Scenario

Your organization's compliance team requires all **access** changes to the vault's payload to be tracked in the same **unified audit trail** as the rest of your Azure infrastructure.

The Solution **Azure RBAC**



Rationale: **RBAC** role assignments integrate natively with the **Azure Activity Log**, providing a **unified single pane of glass** for access auditing, unlike **siload vault settings**.

The Minefield: AZ-500 Exam Traps

Trap 1: The Mix-and-Match Assumption

Do not fall for scenarios suggesting you can use RBAC for **User A** and **Access Policies** for **User B** on the same vault. It is impossible.

Trap 2: The Owner Illusion

Giving someone the 'Owner' or 'Contributor' role on the vault resource does not automatically grant them access to read secrets in RBAC mode.

Why?

Owner/Contributor are Management Plane roles. Reading secrets requires a Data Plane role (like Key Vault Secrets User).

The Blueprint: AZ-500 Access Cheat Sheet

